



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-15
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-15 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation

1 LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation Vulnerability Report Classification TLP:CLEAR Published 2026-07-15 Version 1.0 Author Lost Boys Cyber Report Type Vulnerability Report TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation - Vulnerability Report Published: 2026-07-15 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 2 Table of Contents

4.1. Technical Behavior Summary

5.1. MITRE ATT&CK Mapping

6.1. Microsoft Defender for Endpoint Hunting Queries 6.2. Sigma Rule: Suspicious User Hive Staging and Local AppData Redirection 6.3. Splunk Hunt 6.4. Incident Triage Questions

7.1. Temporary Compensating Controls 7.2. Validation Plan

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 3 LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege Escalation

LegacyHive is a publicly disclosed Windows local privilege-escalation vulnerability affecting the Windows User Profile Service, also known as ProfSvc. The public proof of concept was released by the researcher using the Nightmare-Eclipse / Chaotic Eclipse identity on 14 July 2026, shortly after Microsoft's July Patch Tuesday cycle. The disclosure is notable because the author claims the technique remains functional on all currently supported Windows desktop and server versions with July 2026 updates installed, and because the disclosed code provides defenders and capable adversaries with enough implementation detail to understand the abused primitive even though the public build is intentionally restricted. At the time of this report, no CVE identifier, Microsoft advisory, or vendor patch dedicated to LegacyHive has been confirmed in the reviewed public sources. Public reporting consistently describes the issue as an arbitrary registry hive loading flaw in ProfSvc. The released proof of concept requires credentials for another standard user and a third target username; if successful, it causes the target user's hive to be mounted into the current user's classes-root context. The author states that the original, unreleased version did not require the additional credential and was not limited to the UsrClass.dat hive. Lost Boys Cyber assesses that the public release should be treated as a post-compromise privilege-escalation and lateral-abuse risk rather than a standalone remote compromise. The defensive priority is containment and telemetry coverage. Organizations should restrict local interactive access, reduce unnecessary local accounts, harden workstation administrative practices, and monitor for unusual ProfSvc-driven user-profile loading, access to NTUSER.DAT and UsrClass.dat across user boundaries, suspicious object-manager symbolic link creation, and temporary root-level GUID directories used during exploitation. Because no official fix was identified during review, the control strategy should assume a temporary exposure window until Microsoft publishes authoritative remediation guidance. Field Assessment Report Title LegacyHive Windows User Profile Service Arbitrary Hive

Load Privilege Escalation Report family Vulnerability Report Subject LegacyHive Windows User Profile Service arbitrary hive load privilege escalation Disclosure status Public proof of concept and technical details available CVE status No CVE confirmed in reviewed sources as of 2026-07-15 UTC Affected technology Microsoft Windows ProfSvc / user profile registry hive loading Affected scope Claimed all supported Windows desktop and server versions through July 2026 patch level Exploitation vector Local authenticated context; public PoC requires extra standard- user credentials Primary impact Unauthorized loading and potential read/write access to another user's registry hive context Operational severity High where adversaries can gain low-privilege interactive access; medium where endpoints are tightly controlled Confidence Medium-high for public PoC behavior; medium for full-impact

9. Executive Summary

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 4 claims until Microsoft publishes advisory details

This report answers the following intelligence requirement: What is LegacyHive, what risk does it create for Windows environments, and what should defenders do before Microsoft publishes authoritative remediation? The analysis focuses on practical defender outcomes rather than exploit reproduction. The reviewed evidence supports four operational questions: Requirement Answered by this report Vulnerability identity Public LegacyHive disclosure, no confirmed CVE at writing Exploitation preconditions Local authenticated foothold; public PoC requires a second standard-user credential and target username Defensive exposure Windows endpoints and servers where untrusted users or compromised accounts can run code locally Monitoring strategy Endpoint telemetry for profile hive access, registry user-shell- folder manipulation, object-manager link creation, temporary GUID staging directories, and unexpected ProfSvc activity Analyst assumptions: The reviewed public proof of concept is not treated as a full weaponized exploit chain. It is treated as a reliable indicator of the underlying primitive and likely adversary research direction. No vendor patch is assumed available unless Microsoft later publishes an advisory or out-of-band update. Detection examples below are designed for authorized defensive monitoring and should be tuned against local endpoint telemetry before production alerting.

Lost Boys Cyber reviewed primary and secondary sources available on 15 July 2026 UTC. The original public repository provides the strongest evidence for claimed proof-of-concept behavior, while industry reporting provides useful context on affected versions, disclosure timing, researcher history, and defender urgency. Source Type Key contribution Confidence MSNightmare / LegacyHive GitHub repository Primary disclosure and PoC source States the vulnerability class, public PoC constraints, arbitrary hive-load claim, and July 2026 patch compatibility High for what the author published; medium for claims not independently validated SecurityOnline report, 14 July 2026 Secondary vulnerability reporting Summarizes no-CVE status, no confirmed exploitation, affected supported Windows versions, and interim mitigations Medium Cyber Security News report, 15 July 2026 Secondary vulnerability reporting Describes mounted target hive under current user's classes root and recommends monitoring NTUSER.DAT / UsrClass.dat access Medium The Hacker News report, 15 July 2026 Secondary reporting with Microsoft-response context Confirms ProfSvc description, public PoC preconditions, and Medium

10. Intelligence Requirement

11. Source Review and Confidence

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 5 Microsoft investigation status The Register report, 15 July 2026 Secondary reporting with practitioner commentary Frames LegacyHive as useful post-compromise primitive; quotes practitioner assessment that fully weaponized compromise requires additional work Medium Confidence statement: Confidence is medium-high that LegacyHive represents a real ProfSvc/user-hive handling weakness with a functional public demonstration under constrained preconditions. Confidence is lower regarding exploitability beyond those preconditions because the author explicitly states the public PoC was reduced and Microsoft had not published a technical advisory at the time of review. Defensive recommendations are therefore framed around observable behavior and exposure reduction rather than unverified root-cause claims.

ID Finding Defensive implication Confidence F1 LegacyHive targets Windows ProfSvc handling of user registry hives and can mount another user's hive into the current user's classes-root context. User-profile and registry-hive telemetry become critical detection sources; endpoint teams should not limit monitoring to process creation alone. Medium-high F2 The public PoC is constrained but not harmless: it requires another standard user's credentials and a third target username, but the author claims the original did not require additional credentials and could load arbitrary hives. Capable actors may use the public

code as a starting point to recover missing pieces or develop variants. Treat as an active research-to- weaponization risk. Medium F3 Public sources report no CVE, no Microsoft advisory, and no confirmed in-the-wild exploitation at the time of writing. Patch-based remediation may not be immediately available. Compensating controls and threat hunting are required during the exposure window. Medium-high F4 The PoC source indicates suspicious behaviors: creation of root-level GUID directories, permissive DACLs, object- manager directory and symbolic-link manipulation, modification of User Shell Folders Local AppData, copying UsrClass.dat, opening NTUSER.DAT, and spawning a logged-on helper process. Detection should combine file, registry, process, and advanced endpoint telemetry rather than relying on a single signature. High for PoC- derived behavior F5 The practical threat is post- compromise elevation or cross- user hive access, not internet- scale remote exploitation by itself. Prioritize high-risk shared workstations, jump boxes, VDI, RDS hosts, developer machines, and servers where low-privilege local users can Medium-high

12. Key Findings

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 6 execute code.

4.1. Technical Behavior Summary Windows stores user-specific configuration in registry hive files such as NTUSER.DAT and UsrClass.dat. ProfSvc loads and manages these hives as part of user logon/profile handling. LegacyHive abuses the service's hive-loading behavior to cause a target user's hive to be mounted into another context. Public reporting describes the result as privileged read/write access to another user's hive if exploitation is successful. A review of the public PoC source supports the following behavior-level observations: Behavior Observed in public PoC source Detection value Uses Win32, Native API, UserEnv, Advapi32, Offline Registry APIs, and RPC UUID functions Includes ntdll, UserEnv, AclAPI, offreg, Rpcrt4 Useful for static triage of binaries named as LegacyHive derivatives Creates a random GUID-named directory under C:\ Work directory generated from UuidCreate and concatenated under C:\ High-signal when paired with profile-hive file activity Applies permissive Everyone ACLs to staging directory Explicit DACL grants GENERIC_ALL to Everyone Useful file/ACL anomaly signal Creates object-manager directories and symbolic links under BaseNamedObjects\ \Restricted Native API calls create object directories and symbolic links targeting Windows profile paths High-value EDR telemetry where object- manager events are available Opens and backs up a user's NTUSER.DAT Reads target user hive file into memory Monitor cross-user profile hive access by unusual processes Modifies User Shell Folders Local AppData in hive data Sets Local AppData to \\.\globalroot\ \BaseNamedObjects\ \Restricted Strong registry anomaly if captured before cleanup Copies UsrClass.dat to the staging directory CopyFile from AppData\Local\Microsoft\ Windows\UsrClass.dat Strong file telemetry signal when paired with GUID staging directory Uses an oplock and a helper process launched with another credential FSCTL_REQUEST_BATCH_OPLOCK and CreateProcessWithLogonW Advanced signal for exploit timing behavior Checks RegOpenUserClassesRoot outcome Confirms hive loaded into user classes root Detection value mostly through surrounding behavior Attempts cleanup and hive restoration Deletes staging files and removes directory Hunting should include short-lived artifacts, not only current-state files This report intentionally omits step-by-step exploit reproduction. The behavior above is provided to support defensive detection engineering, incident response triage, and authorized lab validation.

LegacyHive belongs to a recurring 2026 pattern of publicly disclosed Windows local privilege escalation and defense-evasion vulnerabilities released by the Nightmare-Eclipse / Chaotic Eclipse persona. Public reporting states that earlier disclosures in this series were weaponized quickly after publication, including Microsoft Defender-related issues. That history increases the urgency of defensive coverage even though LegacyHive's public PoC appears less complete than prior releases. Local privilege escalation vulnerabilities are frequently used after phishing, credential theft, malicious software execution, or exploitation of a separate remote-facing weakness. They can convert a low-privilege foothold into access that supports credential theft, persistence, lateral movement, and security-control tampering. LegacyHive is especially sensitive because Windows registry hives can influence COM registrations, shell behavior, application launch paths, file associations, and user-

13. Threat Context

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 7 specific configuration. Even if the public PoC only demonstrates hive mounting, variants that permit arbitrary hive load or write access could become powerful building blocks inside a broader intrusion chain. Environment Exposure relevance Defensive priority Shared workstations and kiosks Multiple local profiles increase cross-user hive-abuse opportunities High VDI and RDS hosts Many user profiles and frequent logons create noisy but valuable ProfSvc telemetry High Administrator workstations Hive access to privileged users may expose configuration and escalation paths High Developer workstations Local admin sprawl, build tools, and credentials increase blast radius High Servers with interactive logon disabled Lower direct exposure, but still

relevant if attackers obtain local code execution Medium Consumer endpoints Risk depends on local account model and exposure to commodity malware Medium 5.1. MITRE ATT&CK Mapping Technique Name Relevance T1068 Exploitation for Privilege Escalation LegacyHive is primarily a local privilege- escalation primitive after an attacker can execute code locally. T1112 Modify Registry The public PoC modifies registry hive content, including User Shell Folders values, as part of the profile-loading manipulation. T1106 Native API The PoC calls Native API routines to create object-manager directories and symbolic links. T1059 Command and Scripting Interpreter Not intrinsic to LegacyHive, but likely surrounding tradecraft when attackers deliver, compile, or execute a weaponized tool. T1003 OS Credential Dumping Not directly demonstrated by the public PoC. Included as a downstream risk if hive access is combined with credential material discovery or broader privilege escalation. T1546.015 Event Triggered Execution: Component Object Model Hijacking Not directly demonstrated. Included as a potential downstream risk because user- class hives may influence COM-related behavior.

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 8

Detection should focus on behavior chains rather than a single file name. Public exploit derivatives can be renamed, recompiled, or embedded in another loader. Stronger coverage comes from correlating process, registry, file, and user-profile events around unusual hive access. Detection objective Telemetry Example signal Identify suspicious profile-hive file access EDR file events, Sysmon Event ID 11/15, MDE DeviceFileEvents Non-system process reads or copies C:\Users*\NTUSER.DAT or C:\Users*\AppData\Local\Microsoft\Windows\UsrClass.dat for a different user Identify staging directory creation File events, ACL-change telemetry Short-lived C:\{GUID} directories with permissive Everyone ACLs and hive files beneath them Identify User Shell Folders manipulation Registry events, Sysmon Event ID 13, MDE DeviceRegistryEvents Local AppData set to a globalroot / BaseNamedObjects path or changed shortly before ProfSvc activity Identify helper process behavior Process events, Windows Security 4624/4648, MDE DeviceProcessEvents CreateProcessWithLogon-like behavior spawning benign Windows binaries in suspended or unusual context Identify object-manager abuse EDR advanced telemetry, kernel-object monitoring where available Creation of BaseNamedObjects\Restricted object directories or symbolic links by a non-system process Identify exploit cleanup patterns File deletion and process termination events Hive copy created and deleted in a root- level GUID directory within minutes 6.1. Microsoft Defender for Endpoint Hunting Queries The following KQL queries are designed as starting points. Tune allowed administrative tools, backup agents, EDR products, and profile-management software before enabling alerting.

14. Detection and Hunting

```
// Hunt: suspicious cross-user registry hive file access
let HiveNames = dynamic(["NTUSER.DAT", "UsrClass.dat"]); DeviceFileEvents | where Timestamp > ago(14d) | where
FileName in~ (HiveNames) | where FolderPath has @"\Users\" | where ActionType in~ ("FileCreated", "FileModified",
"FileRenamed", "FileOpened", "FileRead", "FileCopied") | extend ProfileUser = extract(@"\Users\[^\]+\", 1, FolderPath) |
where isnotempty(ProfileUser) | where InitiatingProcessAccountName != ProfileUser | where InitiatingProcessFileName !in~
("svchost.exe", "lsass.exe", "explorer.exe", "SearchIndexer.exe") | project Timestamp, DeviceName, ActionType, FolderPath,
ProfileUser, InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessAccountName,
InitiatingProcessParentFileName, SHA256 | order by Timestamp desc
```

```
// Hunt: root-level GUID staging directories containing profile hive artifacts
DeviceFileEvents
| where Timestamp > ago(14d)
| where FolderPath matches regex @"(?:i)^C:\\[0-9a-f]{8}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{12}\\\"
| where FolderPath has_any ("NTUSER.DAT", "UsrClass.dat", "ntuser.dat")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, InitiatingProcessFileName,
```

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 9

InitiatingProcessCommandLine, InitiatingProcessAccountName, SHA256 | order by Timestamp desc

```
// Hunt: User Shell Folders Local AppData redirected to globalroot/BaseNamedObjects
DeviceRegistryEvents
| where Timestamp > ago(14d)
| where RegistryKey has @"Software\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders"
| where RegistryValueName =~ "Local AppData"
| where RegistryValueData has_any ("globalroot", "BaseNamedObjects", "Restricted")
| project Timestamp, DeviceName, ActionType, RegistryKey, RegistryValueName, RegistryValueData,
```

InitiatingProcessFileName, InitiatingProcessCommandLine, InitiatingProcessAccountName | order by Timestamp desc

```
// Hunt: suspicious use of secondary credentials followed by profile hive access
```

```
let SecondaryLogonProcesses = DeviceProcessEvents | where Timestamp > ago(14d) | where ProcessCommandLine has_any ("runas", "CreateProcessWithLogon", "LOGON_WITH_PROFILE") or InitiatingProcessCommandLine has_any ("runas", "CreateProcessWithLogon", "LOGON_WITH_PROFILE") | project DeviceId, DeviceName, ProcTime=Timestamp, ProcessId, FileName, ProcessCommandLine, AccountName, InitiatingProcessFileName; let HiveAccess = DeviceFileEvents | where Timestamp > ago(14d) | where FileName in~ ("NTUSER.DAT", "UsrClass.dat") | project DeviceId, HiveTime=Timestamp, FolderPath, InitiatingProcessFileName, InitiatingProcessAccountName; SecondaryLogonProcesses | join kind=innerunique HiveAccess on DeviceId | where HiveTime between (ProcTime .. ProcTime + 10m) | project DeviceName, ProcTime, HiveTime, FileName, ProcessCommandLine, AccountName, FolderPath, InitiatingProcessFileName, InitiatingProcessAccountName | order by HiveTime desc
```

6.2. Sigma Rule: Suspicious User Hive Staging and Local AppData Redirection
 rule_title: Potential LegacyHive User Profile Hive Loading Activity id: 6f3bb1de-legacyhive-hive-load-2026
 status: experimental description: Detects behavior associated with the public LegacyHive PoC, including root-level GUID staging directories for user registry hives and Local AppData redirection to globalroot/BaseNamedObjects paths. author: Lost Boys Cyber date: 2026-07-15 references:

logsource: product: windows detection: selection_file_staging: TargetFilename|re: '^C:\\[0-9a-fA-F]{8}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{4}-[0-9a-fA-F]{12}\\.*\\(NTUSER\\.DAT|UsrClass\\.dat|ntuser\\.dat)\$' selection_registry_redirect: TargetObject|contains: '\\Software\\Microsoft\\Windows\\CurrentVersion\\Explorer\\User Shell Folders\\Local AppData\\Details' contains|all:

filter_known_system: Image|endswith:

condition: (selection_file_staging or selection_registry_redirect) and not filter_known_system fields:

- <https://github.com/MSNightmare/LegacyHive>
- <https://thehackernews.com/2026/07/researcher-drops-new-windows-zero-day.html>
- 'globalroot'
- 'BaseNamedObjects'
- '\\svchost.exe'
- '\\explorer.exe'
- '\\SearchIndexer.exe'
- UtcTime

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 10

falsepositives:

legitimately access user hives. Root-level GUID staging plus globalroot redirection should be uncommon and high priority.
 level: high tags:

6.3. Splunk Hunt index=windows (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" OR sourcetype="WinEventLog:Security") ((EventCode=11 OR EventCode=15 OR EventCode=23) (TargetFilename="*\\Users*\\NTUSER.DAT" OR TargetFilename="*\\Users*\\UsrClass.dat" OR TargetFilename="C:*-*-*-**UsrClass.dat")) OR (EventCode=13 TargetObject="*\\Software\\Microsoft\\Windows\\CurrentVersion\\Explorer\\User Shell Folders\\Local AppData\\Details="*BaseNamedObjects*") | eval legacyhive_signal=case(match(TargetFilename,"(?:)^C:\\[0-9a-f]{8}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{4}-[0-9a-f]{12}\\.*\\(NTUSER\\.DAT|UsrClass\\.dat|ntuser\\.dat)\$"),"root_guid_hive_staging",

like(Details,"%BaseNamedObjects%"),"local_appdata_globalroot_redirect", like(TargetFilename,"%\\Users\\%"),"cross_user_hive_access", true(),"other") | table _time host user EventCode Image CommandLine TargetFilename

TargetObject Details legacyhive_signal | sort - _time

6.4. Incident Triage Questions Which account executed the suspected binary, and did that account normally have local interactive access to the device? Did the process access another user's NTUSER.DAT or UsrClass.dat? Was a short-lived C:\\{GUID} directory created, modified, or deleted? Did any registry value under User Shell Folders change to a \\globalroot\\BaseNamedObjects path? Did ProfSvc, svchost.exe hosting ProfSvc, or a newly spawned process load or access a user hive around the same time? Did the suspected account subsequently access LSASS, credential stores, browser data, DPAPI material, privileged shares, or administrative tools? Were new COM registrations, shell extension values, Run keys, service configurations, or file associations written into the mounted hive?

- Computer
- User
- Image
- CommandLine
- TargetFilename
- TargetObject
- Details
- Profile-management tools, backup agents, forensic acquisition, and endpoint management software may
- attack.privilege_escalation
- attack.t1068
- attack.defense_evasion
- attack.t1112

Priority Recommendation Owner Rationale P0 Track Microsoft advisory and apply the first official fix or mitigation as soon as it is released. Endpoint engineering / vulnerability management LegacyHive appears unpatched in July 2026 public reporting. Vendor guidance should supersede interim workarounds. P0 Disable or tightly restrict unnecessary local interactive logon for non-administrative accounts on servers, jump hosts, admin workstations, and shared systems. Identity / endpoint engineering The flaw is local. Reducing who can execute code locally directly reduces exploit opportunity. P1 Reduce local account sprawl Identity / endpoint engineering The public PoC requires

15. Recommendations

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 11 and remove stale local standard-user accounts. another standard-user credential; fewer local accounts reduces the public variant's viability. P1 Deploy the provided hunts for NTUSER.DAT / UserClass.dat cross-user access and User Shell Folders globalroot redirection. Detection engineering / SOC These behaviors map directly to the public PoC and provide early visibility before patch availability. P1 Increase monitoring on shared workstations, VDI/RDS hosts, helpdesk/admin systems, and developer endpoints. SOC / endpoint engineering These systems have higher likelihood of multiple user hives, privileged profiles, or attacker interest. P2 Harden local administrator usage with LAPS/Windows LAPS, just-in-time admin, credential guard, and separate admin workstations. Identity / security architecture Limits downstream impact if attackers combine hive access with credential or persistence techniques. P2 Add EDR watchlists for root-level GUID staging directories, object-manager symbolic-link abuse where telemetry exists, and suspicious Offline Registry API usage. Detection engineering Helps catch public PoC derivatives and modified implementations. P2 Conduct authorized lab validation only in isolated systems and record benign baseline events for tuning. Security engineering Validates detection coverage without risking production systems or spreading exploit code. 7.1. Temporary Compensating Controls Until an official patch or mitigation is available, prioritize the following controls: Enforce least privilege for local logon rights through Group Policy and endpoint-management baselines. Review membership of local Users, Remote Desktop Users, Backup Operators, Helpdesk, and local Administrators groups. Require separate, hardened admin accounts and prohibit daily-driver browsing or email from admin workstations. Monitor for successful and failed use of alternate credentials on endpoints, including Event ID 4648 where available. Alert on unexpected access to another user's profile hive files by non-system processes. Preserve forensic evidence quickly during investigation; the public PoC attempts cleanup and can leave short-lived artifacts. 7.2. Validation Plan Defenders should validate coverage in a controlled lab without running untrusted code in production: Step Validation objective Evidence to collect 1 Baseline normal profile loading and login behavior ProfSvc events, hive file access, process tree, registry events 2 Simulate benign hive-file access with approved forensic tooling Confirm detections do not over-alert on known tools after allowlisting

TLP:CLEAR | Lost Boys Cyber | LegacyHive Windows User Profile Service Arbitrary Hive Load Privilege... 12 3 Monitor for root-level GUID directory creation and deletion Confirm file telemetry captures short-lived staging artifacts 4 Simulate suspicious Local AppData redirection to a nonstandard path in a lab hive Confirm registry detection logic triggers and records process context 5 Correlate process, registry, and file timelines Validate SOC runbook can reconstruct sequence and escalation risk

[1] MSNightmare, "LegacyHive: Windows user profile service arbitrary hive load elevation of privileges vulnerability," GitHub repository, accessed 2026-07-15. <https://github.com/MSNightmare/LegacyHive> [2] SecurityOnline, "LegacyHive:

Exploit Code and Full Details Publicly Disclosed for Unpatched Windows Privilege Escalation Flaw,” 2026-07-14. <https://securityonline.info/legacyhive-windows-exploit/> [3] Cyber Security News, “New LegacyHive Windows 0-day Vulnerability Allows Users to Load Another User’s Registry,” 2026-07-15. <https://cybersecuritynews.com/legacyhive-windows-0-day-vulnerability/> [4] The Hacker News, “Researcher Drops New Windows Zero-Day PoC Hours After Microsoft Patch Tuesday,” 2026-07-

[5] The Register, “LegacyHive: ‘Bone-shattering’ zero-day from Microsoft’s serial tormentor not the haymaker that was promised,” 2026-07-15. <https://www.theregister.com/security/2026/07/15/microsofts-serial-tormentor-drops-legacyhive-0-day/5271723>

16. References

17. <https://thehackernews.com/2026/07/researcher-drops-new-windows-zero-day.html>